

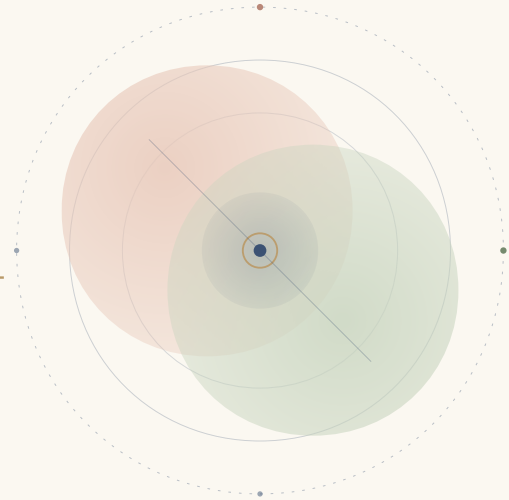
FUTURENSE AI CLINIC

Proprietary Engagement Material · IIT Roorkee × FutureNSE Technologies

SPRINT 2 – 3 COMBINED ENGAGEMENT

Project KAVACH

A two-surface security assessment for a fictional non-banking financial enterprise. Network forensics meets web application security, with synthesis as the deliverable.



PROGRAMME

PG Certification in
AI-Enabled
Cybersecurity

DURATION

Four iterations
across four weeks

FORMAT

Team engagement
GitHub-driven, async-
first

00 · OVERVIEW

Engagement at a Glance

ENGAGEMENT Combined network forensics + web application security assessment	DURATION Four one-week iterations · three active, one synthesis	FORMAT Team engagement, async-first, GitHub-driven
TOOLING Free-tier & open-source only · personal laptop	OUTCOME Reproducible deliverable pack + individual reflection	POSITION Compounds into the next sprint and the capstone

The Engagement Architecture

Three workstreams, one synthesis. Workstreams A and B run in parallel from Iteration 2; Workstream C joins them in Iteration 4.

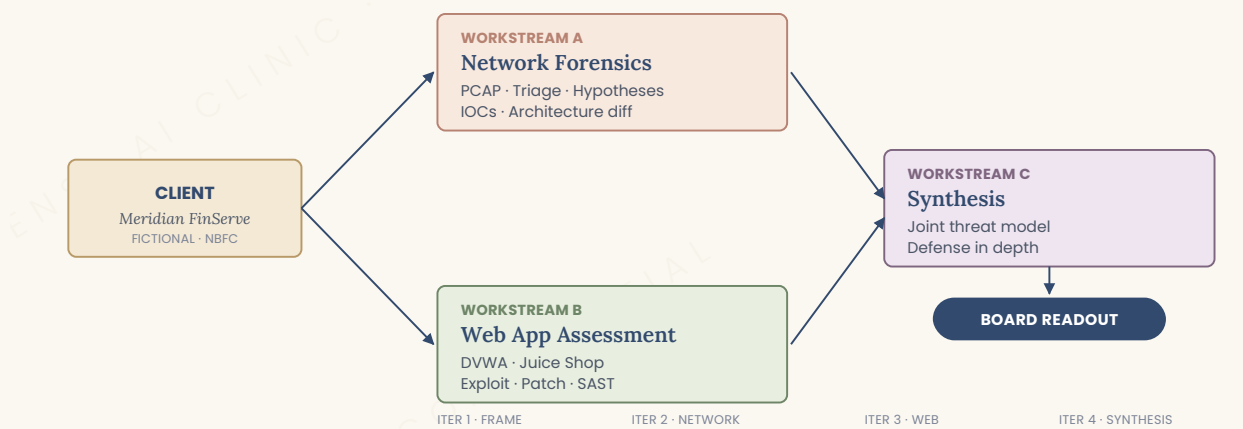


Figure 01 — Three workstreams converge into a single board-level readout

CLUE · 00

"Two surfaces" is a hypothesis, not a finding. The engagement begins by treating the network anomalies and the portal disclosure as related; it ends by either substantiating or dismissing that link with evidence. Either outcome is valid; an undecided one is not.

The Engagement Brief

1.1 Client Profile

Meridian FinServe Pvt. Ltd. is a fictional mid-sized Indian non-banking financial company headquartered in Mumbai with a presence across nine cities. The company offers SMB lending, merchant payments, and an embedded credit product. Roughly 720 employees support a customer base of approximately 180,000 borrowers and 22,000 merchants. The company operates a customer-facing portal — used for lending applications, EMI servicing, and statements — and a partner portal for merchant onboarding and reconciliation. Internal traffic flows between branch offices, two co-located data centers, and a small public-cloud footprint.

1.2 Triggers for the Engagement

Two events, in the same fortnight, drove the board to commission an independent security review:

TRIGGER A · NETWORK

The internal SOC reported a **72-hour window of anomalous east-west and outbound traffic** from a server segment that historically generates predictable, low-variance flows. The on-call team triaged but did not isolate a root cause. A full packet capture of the window was preserved.

TRIGGER B · WEB

A bug-bounty researcher submitted a coordinated disclosure indicating the customer portal contains **at least one SQL-injectable endpoint and an IDOR** on an account-statements path. The researcher provided proof-of-concept details but did not exhaust the surface.

The board has decided to commission a single, time-boxed assessment that treats both signals as related until proven otherwise.

1.3 Engagement Objectives

- Reconstruct what happened on the network during the captured window, with confidence levels assigned to each finding.
- Independently verify, expand, and document the web application weaknesses, then propose code- or configuration-level fixes.
- Synthesise both findings into a defense-in-depth recommendation that an engineering leadership audience can fund and a board can sign off on.
- Deliver everything as artifacts a future internal team could pick up and continue from.

1.4 Scope

IN SCOPE	OUT OF SCOPE
One captured PCAP representing the 72-hour incident window	Live testing against any production system, real or simulated

Vulnerability assessment of the portal — represented by self-hosted DVWA + OWASP Juice Shop	Social engineering, physical, or insider-threat assessment
Joint threat model spanning both surfaces	Compliance attestation under RBI, ISO 27001, or PCI DSS
Network architecture and application-layer remediation proposals	Source-code access to internal banking-core or payment-rails services
One-page executive readout	Anything requiring paid tools, paid APIs, or a cloud bill

1.5 Constraints & Success Criteria

- All tooling is free-tier or open-source. Anything that runs must run on a personal laptop.
- Findings must be reproducible from the artifacts in the team's repository, by someone who was not on the team.
- No real PII appears in any artifact; incidental sensitive strings from public PCAPs are replaced with synthetic data.
- The engagement is successful when an independent reader, given only the GitHub repository, can reconstruct what was found, why it is believed, how it would be fixed, and what trade-offs were considered.

CLUE · 01

Read the brief twice before opening any tool. The second reading is the one that finds the constraint that will most shape the engagement — usually a sentence that did not stand out the first time.

02 · TECHNICAL

The Three Workstreams

This section is the product-and-design specification. The Client Brief describes *what* the client wants; this section describes *what the team must build*. Both are binding.

A Network Forensics & Architecture

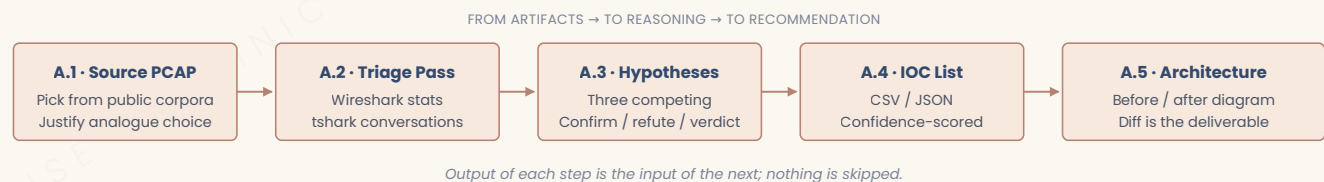


Figure 02 — Workstream A pipeline

A.1 Source PCAP. Select one capture from a public corpus — Malware-Traffic-Analysis.net, the Wireshark Sample Captures wiki, NETRESEC public repositories, or the CIC datasets. The chosen capture must contain at least one of: command-and-control beaconing, lateral movement, data exfiltration, scanning, or credential abuse. Document why this capture is a defensible analogue of the Meridian FinServe scenario.

A.2 Triage Pass. Produce a high-level inventory: protocols, endpoints, conversations, top talkers, time bounds, anomalous bursts. Use Wireshark statistics views and `tshark` on the command line.

A.3 Hypothesis-Driven Deep Dive. Form at least three competing hypotheses about what the traffic represents, then test each against the data. Each hypothesis carries: what would confirm it, what would refute it, and the verdict. The deliverable is the reasoning, not the answer.

A.4 Indicator Extraction. Produce a structured IOC list — IPs, domains, file hashes (where reconstructable), URI patterns, JA3/JA3S fingerprints, user-agent strings, suspicious DNS patterns. Each indicator carries a confidence rating and the packet ranges that support it. Machine-readable, not embedded in prose.

A.5 Architecture Proposal. Produce the relevant Meridian FinServe segment as it stands, then the proposed hardened version. The diff is the deliverable. Mermaid sources or draw.io / Excalidraw exports are acceptable.

CLUE · A

Baseline first, anomaly second. Triage is not "find the suspicious"; it is "characterise the normal". An anomaly only has meaning against a baseline. DNS, in particular, is loud — C2 channels often hide there because operations teams stop watching it after the first quarter.

B Web Application Security Assessment

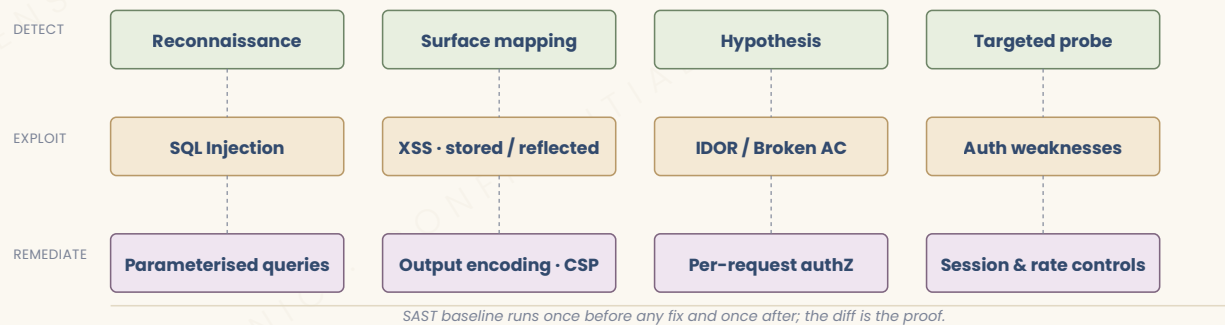


Figure 03 — Workstream B: every finding traverses detect, exploit, and remediate

CLUE · B

Filters fall to encoding before they fall to cleverness — the next move after a rejected payload is rarely a smarter payload, it is the same one encoded differently. And authorisation is a layer, authentication is a door: auth failures sit in per-request access checks, not in the login flow.

B.1 Test Environment

Stand up **DVWA** and **OWASP Juice Shop** locally via Docker. DVWA covers the SQL-injection and classic-web-vulnerability track; Juice Shop covers the modern, JavaScript-heavy, API-driven track. Both together approximate a real-world customer portal better than either alone. Document the docker-compose, the seed state, and how a reviewer reproduces the environment in under fifteen minutes.

B.2 Required Coverage

Demonstrate exploitation of at least **five OWASP Top 10 (2021)** categories. Three are mandatory: **A01 Broken Access Control** (including IDOR), **A03 Injection** (SQLi and at least one XSS variant — reflected, stored, or DOM), and **A07 Identification & Authentication Failures**. The remaining two are at the team's discretion.

B.3 Attack Path Documentation

For each finding: request/response evidence (curl, Burp Community, or ZAP), the exact payload, the underlying cause in one or two sentences, and the impact in business terms in one sentence — what could a real attacker do at Meridian FinServe with this.

B.4 Remediation & Static Analysis Baseline

For each finding, deliver one of: a code-level patch as a commit on a fix branch, a configuration change as a file diff, or a compensating control with the cost made explicit. **At least three findings carry actual code-level patches**, not only configuration recommendations. Run a free SAST scanner — Semgrep CE with default OWASP rulesets, Bandit for Python, ESLint security plugins for JavaScript — and capture both the *before* and *after* reports. The diff is one of the most concrete pieces of evidence in the engagement.

C Synthesis · Joint Threat Model & Defense in Depth

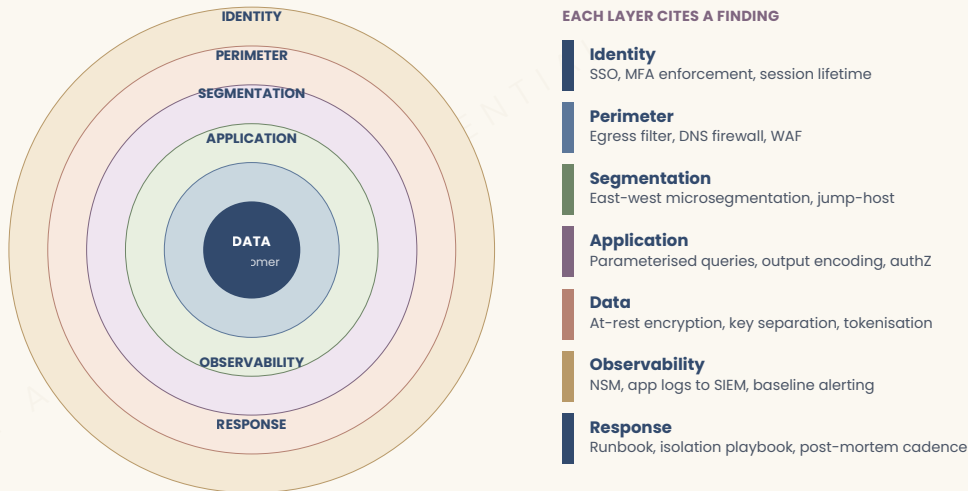


Figure 04 – Defense in depth: every layer carries a citation back to a Workstream A or B finding

CLUE · C

Defense in depth is not depth in defense. Seven layers each at 80% strength is more secure than one layer at 99%. Cost the proposal accordingly – what does each layer add that the layer above it cannot. The board does not buy controls; it buys outcomes.

C.1 Joint Threat Model

Produce a STRIDE- or PASTA-style threat model that treats Meridian FinServe as a single system, not two. The model must show **at least two threats whose realisation depends on a chain that crosses both surfaces** – a network observation that a web compromise is taking place, or a web pivot whose downstream movement appears at the network layer. This is the workstream that distinguishes a generic dual-deliverable from a real engagement.

C.2 Defense-in-Depth Proposal

One document, layered as: identity, perimeter, segmentation, application, data, observability, response. Each layer cites a specific finding from Workstream A or B as motivation. Each control is annotated with implementation effort (S / M / L) and a one-line trade-off – what does this control cost, slow down, or break.

C.3 Executive Readout

A one-page document for a non-technical board audience. **Three findings, three recommendations, one ask.** No jargon a non-technical board member would not already know. If a sentence in this document needs a footnote to be understood, the sentence is rewritten.

Operating Constraints & Tooling Stack

The engagement runs entirely on free-tier and open-source software, on each participant's personal laptop. No paid licences, no privileged Meridian FinServe data, and no production access. The constraint is deliberate — it forces the engagement onto the same primitives a defender or independent reviewer would actually have, and makes every result reproducible by anyone with a laptop and an evening.

ENVIRONMENT Personal laptop · Docker Desktop free-tier · 16 GB RAM recommended · no privileged production access	DATA PCAPs from public corpora only · all credentials and PII synthesised · no Meridian FinServe production traffic
LICENSING Free-tier tools only · Burp Community, ZAP, Semgrep CE, GitHub Free · no commercial scanners or enterprise SIEM	REPRODUCIBILITY A reviewer with this repo and one evening must reproduce every finding · environment up in <15 minutes

3.1 Tooling Stack

PACKET ANALYSIS Wireshark, tshark, Zeek, Suricata	WEB TESTING OWASP ZAP, Burp Community, curl
TEST APPS DVWA, OWASP Juice Shop (Docker)	STATIC ANALYSIS Semgrep CE, Bandit, ESLint security
CONTAINERS / VMS Docker Desktop, VirtualBox, Kali ISO	DIAGRAMS Mermaid, draw.io, Excalidraw
VERSION CONTROL GitHub (free public or private)	LLM ACCESS Free tiers · Claude, ChatGPT, Gemini, Ollama

The Four-Iteration Plan

The engagement runs four iterations of one calendar week each. Iterations are scoped by *goal*, not by absolute date. The team chooses its own start day; once chosen, iteration boundaries are honoured. Each iteration is bracketed by two lightweight ceremonies — a goal-setting check at the start and a closing check at the end. Mid-iteration synchronisation is asynchronous; the GitHub Project board is the single source of truth.

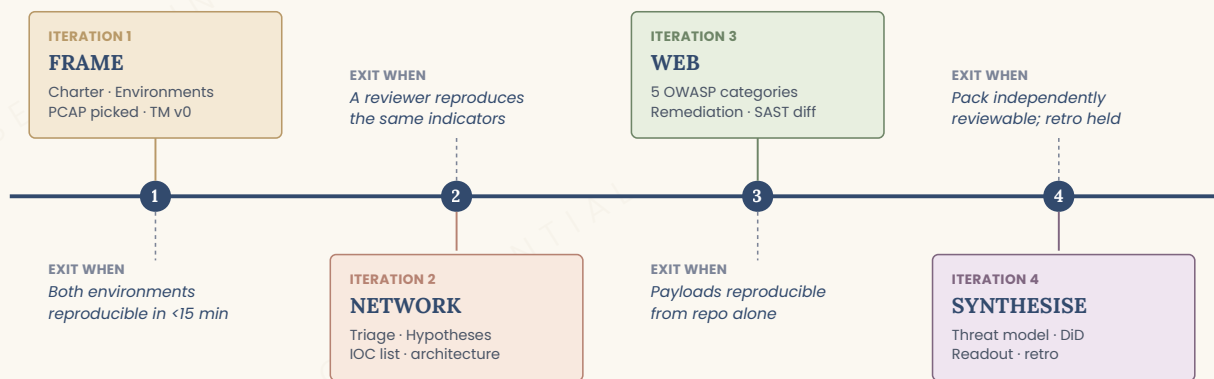


Figure 05 — Iteration spine, with exit conditions rather than calendar dates

#	THEME	GOAL	EXIT CONDITION
1	Frame	Charter signed off internally; both test environments stood up; PCAP selected; threat model v0 sketched.	Anyone on the team can reproduce both environments from the repo in under 15 minutes.
2	Network	Workstream A delivered through A.4 (IOC list); architecture proposal in draft.	A reviewer can re-run the analysis from the notebooks alone and arrive at the same indicators.
3	Web	Workstream B delivered through B.4 (remediation artifacts); SAST baselines captured.	All required vulnerability categories demonstrated with reproducible payloads in the repository.
4	Synthesise	Workstream C complete; deliverable pack frozen; executive readout dry-run; individual questionnaires submitted.	The deliverable pack is independently reviewable; the team has run a retrospective.

05 · GITHUB

GitHub as the Continuous Spine

GitHub is not a place to upload final files. It is the working surface of the engagement. A reviewer should be able to read the commit history end-to-end and see the team think.

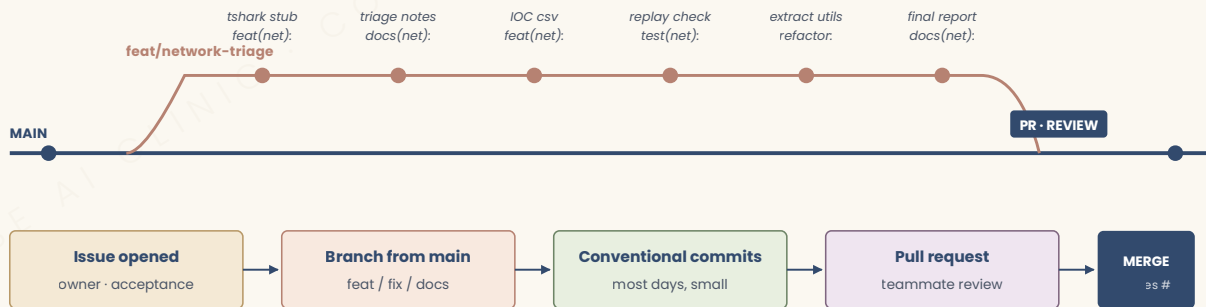


Figure 06 — Issue to merge, the loop the team runs many times a week

Required Practices

1. **Repository on day one.** The README is the engagement charter. It evolves; the diff is the change log.
2. **Branches, not main.** All meaningful work lands via pull request, with at least one teammate review. Self-merging without review is a working-alone smell.
3. **Conventional Commits.** Pattern: `type(scope): subject` — e.g. `feat(network): add tshark triage notebook`. Subject lines imperative, under 72 characters. Bodies for the *why*.
4. **Issues track the work.** Each work item is an Issue with an owner and an acceptance line. Closing without linking to the artifact that closed it is not done.
5. **Project board mirrors the iteration.** Backlog · In Progress · Review · Done. WIP per person bounded; if more than two cards In Progress, the team pauses.
6. **Frequency.** Commits on most days the team is active. A multi-day silence followed by a single mega-commit is a smell.
7. **No sensitive material.** No real PII, no real customer data, no captured secrets. Synthetic substitutes only.

LLM as a Creative Force-Multiplier

Large language models are encouraged throughout the engagement. They are not a substitute for thinking. The bar is simple: **would the team have arrived at the same conclusion if the LLM session had never happened?** If the answer is no — because the LLM did the reasoning — the conclusion is suspect.

ENCOURAGED

- Summarising protocol documentation when triaging unfamiliar protocols
- Generating candidate SQL or XSS payloads to test (team verifies which work and why)
- Drafting a first pass of report sections for the team to rewrite
- Explaining a packet's bytes when intuition fails
- Suggesting alternative architectures the team had not considered
- Code review on remediation patches before PR
- Translating a finding between technical depth and executive concision

DISCOURAGED

- Pasting LLM output into a deliverable verbatim, in any section
- Accepting LLM-claimed CVEs, threat-actor attributions, or statistics without primary-source verification
- Letting the model invent IOCs, IP addresses, or domain names that are not in the actual capture
- Using LLMs to author the threat model or executive readout end-to-end
- Substituting an LLM summary for reading the OWASP or RFC primary source when stakes are high
- Using LLMs to generate the questionnaire answers in §8 (auto-disqualifying)
- Treating model agreement as validation rather than a prompt to triangulate

Prompt Logging

Each member maintains a running prompt log at `prompts/[handle].md`. The log captures, for at least eight prompts across the engagement: the prompt itself, the tool used, what came back, what the member did with it, and where it went wrong if it did. **The most interesting entries are the failure modes** — the moments where the model was confidently wrong. Those are the entries reviewers read first.

CLUE · LLM

A model that agrees with you is not validating you; it is mirroring you. The prompt that produced an answer the team already wanted is not a useful prompt. The useful prompts are the ones that pushed back, that surfaced an angle the team had not considered, or that confidently produced a wrong answer the team caught.

Team Operating Model

Engagements like this rarely have everyone contributing at the same intensity. The structure here assumes uneven contribution and is built so the active members can ship without waiting.

- **Modular work units.** Every Issue is sized so one person can complete and close it. There are no multi-person dependencies that block a workstream. If two pieces of work must happen in sequence, they are two Issues, not one.
- **Public surface.** Because GitHub is the working surface, contribution is visible in the commit history, the Issues closed, the reviews left, and the documents authored. There is no need to track who did what separately.
- **Two levers when carrying disproportionate weight.** Re-pull from the Backlog rather than waiting; trim scope at the next iteration boundary by closing low-value Issues with a short note. Both moves are first-class. The engagement is designed to be completable by a determined subset of the team.

07 · DELIVERABLES

The Deliverable Pack

The engagement closes with this pack, all in the repository. The structure itself is part of the deliverable – a reviewer should be able to find any artifact without asking.



Figure 07 — The deliverable pack, organised by workstream

08 · REFLECTION

Individual Reflection Questionnaire

Each team member submits an individual response. The questions are deliberately written so that surface-level participation is visible immediately. **Generic answers — even articulate ones — fail. Specificity is the only currency.**

- Q1** Identify a specific packet, frame, or flow in your chosen capture that changed how you thought about what was happening. Cite the packet number or time offset, the protocol-level detail that mattered, and what your interpretation was before versus after.
- Q2** Describe one hypothesis your team formed about the network capture that turned out to be wrong. What evidence had drawn you to it, and what evidence falsified it.
- Q3** Pick one vulnerability your team demonstrated in the web environment. Walk through the exact payload progression — what you tried first, what failed, what you adjusted, and the final working payload. Include a moment where you understood why an earlier attempt did not work.
- Q4** For the same vulnerability, describe the remediation you wrote at the code level. Why did you choose that fix over at least one alternative the team considered. What does the alternative cost or break that yours does not.
- Q5** Where in the engagement did an LLM mislead you. Quote or paraphrase the specific output, explain how you noticed it was wrong, and describe what you did instead.
- Q6** Identify one finding from your network analysis that a determined attacker could have used as a stepping stone toward the web portal — or one finding from your web analysis whose downstream behaviour would appear at the network layer. Describe the chain.
- Q7** What is one decision in the defense-in-depth proposal that you would lose sleep over if you were the CISO who had to fund it. What is the trade-off, and why did the team still recommend it.
- Q8** Look at your repository's commit history. Identify the commit you are most proud of and the commit you would, on reflection, redo. Explain both in one sentence each.

Responses that paraphrase the deliverables back, or that read as though they could have been written without doing the work, are returned for revision. There is no length requirement; precision is the requirement.

09 · RECOGNITION

Recognition & Public Voice

A team that completes the engagement to the level described in this brief — reproducible artifacts, deliverable pack frozen, individual questionnaires submitted with specificity — closes the engagement on the strength of that work alone.

Beyond closure, two recognition tiers exist:

TIER · DISTINCTION

Industry Certification by Futurense

Awarded to teams whose work meets a high external bar: reproducibility, depth of analysis, quality of writing in the executive readout, and evidence of independent thinking. Members receive an **industry certification** issued by Futurense, attesting to the depth and scope of the engagement. The certification carries the engagement codename and the workstreams completed, and is intended to be referenceable on a resume and a LinkedIn profile.

TIER · FEATURE

Public Feature on LinkedIn

Individuals whose contribution is independently visible as **extraordinary** — measured against the engagement, not against teammates — are featured on the Futurense AI Clinic LinkedIn surface and tagged in programme-level posts. Visibility is determined by what is in the repository, the questionnaire, and the executive readout.

Both tiers are awarded based on what is in the repository and the questionnaires. Self-reported effort does not enter the calculation.

Post-Engagement LinkedIn Awareness

After the engagement closes, each member is expected to publish **one LinkedIn post** that reflects on what was learned. This is a professional artifact, not a marketing one. The bar: would a hiring manager who read this post want to talk to the author.

- **Lead with a specific lesson.** "I learned defense in depth is important" is not a post. "I spent two hours convinced an unusual DNS pattern was beaconing before realising it was a misconfigured update agent — and what that changed about how I triage" is a post.
- **No proprietary scenario detail.** The fictional client's name, the specific capture chosen, the questionnaire questions, and the internal architecture of this brief are not for the public surface. Lessons are.
- **Tag the programme.** Mention **#FuturenseAIClinic** and tag **@Futurense**. Reference IIT Roorkee and the programme by its public name. Use **#Cybersecurity**, **#AppSec**, and **#NetworkSecurity** where relevant.
- **Repository linking is optional.** If the team has decided to make the repository public, link it. Default is private; the team decides together.

- **One post per member.** Not a coordinated cross-tagging campaign. The posts that resonate read like a person who actually did the work.

The strongest posts are amplified from the Futureense AI Clinic LinkedIn account.

CLUE · VOICE

A LinkedIn post written before the engagement closes is a draft. A LinkedIn post written the day the engagement closes is a victory lap. A LinkedIn post written a week later — with one specific lesson, written in your voice — is the one that gets read.

10 · CLOSE

Intellectual Property & Confidentiality

This brief, the scenario it describes, the questionnaire, and the recognition framework are **proprietary intellectual property of Futureense AI Clinic**. The brief is licensed to the cohort for the duration of the engagement and as a personal portfolio reference afterward.

Meridian FinServe Pvt. Ltd. is a fictional construct created for this engagement. Any resemblance to a real entity is unintentional. Public corpora referenced in this brief — Malware-Traffic-Analysis.net, OWASP test applications, the Wireshark sample captures, the NETRESEC repositories, and the CIC datasets — retain their original licenses; teams are responsible for honouring those licenses in any public artifact they produce.

Redistribution of this brief outside the cohort, in whole or in part, is not permitted without written authorisation from Futureense AI Clinic.

END OF BRIEF · PROJECT KAVACH

Futureense AI Clinic · IIT Roorkee × Futureense Technologies
PG Certification in AI-Enabled Cybersecurity